

■ ■ ARGUS Security Assessment Report (SIH26163)

Target: World Monitor (Local Self-Hosted Instance) | Framework: OWASP Top 10, CWE, CVSS v3.1

1. Executive Summary

Total Endpoints	Correlated Findings	High Severity	Medium Severity
166	12	1	11

2. Scope Area Evaluation Matrix

Scope Area	Status	Audit Notes
1. Auth & Session	Hardened / Edge Bypass	Clerk JWT & wm_* API keys; regex heuristic bypass in middleware.ts
2. Authorization	Hardened	137 public routes, 29 Pro routes with Convex entitlement checks
3. Input Validation	Vulnerable	357 Trusted Types bypass sites in dom-utils.ts; SSRF TOCTOU rebinding
4. API Security	Vulnerable	Fail-open rate limiter degradation exposes endpoints during Redis outage
5. Client-Side	Hardened / Sinks	CSP enforced; DOM writes unescaped via trustedHtml
6. Communication	Hardened	HTTPS & HSTS enforced; Tauri IPC gated with CSPRNG token (5-min TTL)
7. Data Storage	Hardened	No tokens in localStorage; desktop uses OS Credential Manager
8. AI Security	Vulnerable	LLM prompt injection sanitizer uses static regex blocklist

3. Detailed Evidenced Findings

ARGUS-CONFIRMED-009: Unmetered Resource Consumption via Fail-Open Rate Limiter Degradation

Severity: High | CVSS v3.1: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H) | CWE: CWE-770 | OWASP: A04:2021-Insecure Design

Affected Component: api/_rate-limit.js, api/_rate-limit-fallback.js

Description: The edge function rate limiting subsystem degrades availability-first. When Upstash Redis is unreachable, unconfigured, or times out, checkRateLimit() returns null (allowing requests) and emits `X-RateLimit-Mode: degraded`. This leaves expensive upstream endpoints (such as Nominatim reverse geocode and chat analyst LLM calls) vulnerable to unbounded denial-of-service and provider API quota exhaustion.

Remediation: For high-cost and third-party bounded endpoints (such as Nominatim and AI inference), enforce fail-closed rate limiting or in-memory token buckets rather than complete unthrottled fail-open.

Evidence: api/_rate-limit.js: catch block and missing-env check return null unconditionally

ARGUS-CONFIRMED-001: @vitest/mocker: Vitest: Path Traversal / Arbitrary File Read via @vitest/mocker Redirect Mock

Severity: Medium | CVSS v3.1: 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N) | CWE: CWE-22 | OWASP: None

Affected Component: package.json

Description: Package @vitest/mocker (range: >=2.1.0 <4.1.11) has vulnerability: Vitest: Path Traversal / Arbitrary File Read via @vitest/mocker Redirect Mock. See advisory: <https://github.com/advisories/GHSA-82fw-gwww-q-j7x9>

Remediation: Apply input sanitization, strict boundary checks, and defensive controls.

Evidence: Dependency: @vitest/mocker

ARGUS-CONFIRMED-002: image-size: image-size: JXL and HEIF parsers allow denial of service through infinite loops

Severity: Medium | **CVSS v3.1:** 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N) | **CWE:** CWE-835 | **OWASP:** None

Affected Component: package.json

Description: Package image-size (range: >=1.2.0 <=2.0.2) has vulnerability: image-size: JXL and HEIF parsers allow denial of service through infinite loops. See advisory: <https://github.com/advisories/GHSA-5p2g-fcmc-qvqq>

Remediation: Apply input sanitization, strict boundary checks, and defensive controls.

Evidence: Dependency: image-size

ARGUS-CONFIRMED-003: ip-address: ip-address: Address6.isLinkLocal() recognizes fe80::/64 rather than fe80::/10, allowing SSRF and trust-boundary bypass to on-link hosts

Severity: Medium | **CVSS v3.1:** 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N) | **CWE:** CWE-697 | **OWASP:** None

Affected Component: package.json

Description: Package ip-address (range: <=10.5.0) has vulnerability: ip-address: Address6.isLinkLocal() recognizes fe80::/64 rather than fe80::/10, allowing SSRF and trust-boundary bypass to on-link hosts. See advisory:

<https://github.com/advisories/GHSA-rpw4-54j3-4h4q>

Remediation: Apply input sanitization, strict boundary checks, and defensive controls.

Evidence: Dependency: ip-address

ARGUS-CONFIRMED-004: ip-address: ip-address: no classifier recognizes the NAT64 local-use range 64:ff9b:1::/48, allowing SSRF and trust-boundary bypass

Severity: Medium | **CVSS v3.1:** 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N) | **CWE:** CWE-918 | **OWASP:**

A10:2021-Server-Side Request Forgery

Affected Component: package.json

Description: Package ip-address (range: >=10.2.0 <=10.5.0) has vulnerability: ip-address: no classifier recognizes the NAT64 local-use range 64:ff9b:1::/48, allowing SSRF and trust-boundary bypass. See advisory:

<https://github.com/advisories/GHSA-2vr4-cq9g-pvrc>

Remediation: Apply input sanitization, strict boundary checks, and defensive controls.

Evidence: Dependency: ip-address

ARGUS-CONFIRMED-005: stream-json: stream-json: pick/ignore/filter/replace filters are O(depth²) on nested input — small crafted JSON blocks the event loop for seconds→minutes (DoS)

Severity: Medium | **CVSS v3.1:** 6.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N) | **CWE:** CWE-407 | **OWASP:** None

Affected Component: package.json

Description: Package stream-json (range: <=3.4.0) has vulnerability: stream-json: pick/ignore/filter/replace filters are O(depth²) on nested input — small crafted JSON blocks the event loop for seconds→minutes (DoS). See advisory:

<https://github.com/advisories/GHSA-528h-pc64-c93x>

Remediation: Apply input sanitization, strict boundary checks, and defensive controls.

Evidence: Dependency: stream-json